密码学安全与常用攻击方法调研

陈张萌

2023/8/30

目录

- 哈希
- RSA

基础知识

- 唯密文攻击：敌手只拥有密文y
- 已知明文攻击：敌手拥有明文串x及其对应的密文y
- 选择明文攻击：敌手可获得对加密机的临时访问权限，这样他能够选择一个明文串x，并可获得相应的密文串y
- 选择密文攻击：敌手可获得对解密机的临时访问权限，这样他能够选择一个密文串y，并可获得相应的明文串x

哈希

对于任意长度的消息m，生成固定长度的哈希值H(m)
密文空间比明文空间要小，单向
常用：SHA-256，SM3等

哈希函数常用构造方法：海绵结构

数据结构：

- a state of b bits, which is split into two parts:
  - the outer part of the state: the first r bits of the state
  - the inner part of the state: the last c = b − r bits of the state

数据初始化：

- padding message and cut it into r-bit blocks
- the b state bits are initialized to zero

哈希函数常用构造方法：海绵结构

消息处理：

- **absorbing phase**, the message blocks are processed iteratively by **XORing** each block into the first r bits of the current state, and then applying **a fixed permutation** on the value of the b-bit state.
- **squeezing phase**, n output bits are produced iteratively, where in each iteration the first r bits of the state are returned as output and the permutation is applied.

Keccak介绍

1. Padding message

- Keccak hash function uses multi-rate padding: it first appends a single 1 bit. Then, it appends the minimum number of 0 bits followed by a single 1 bit, such that the length of the result is a multiple of r.

Keccak介绍

2. 数据结构

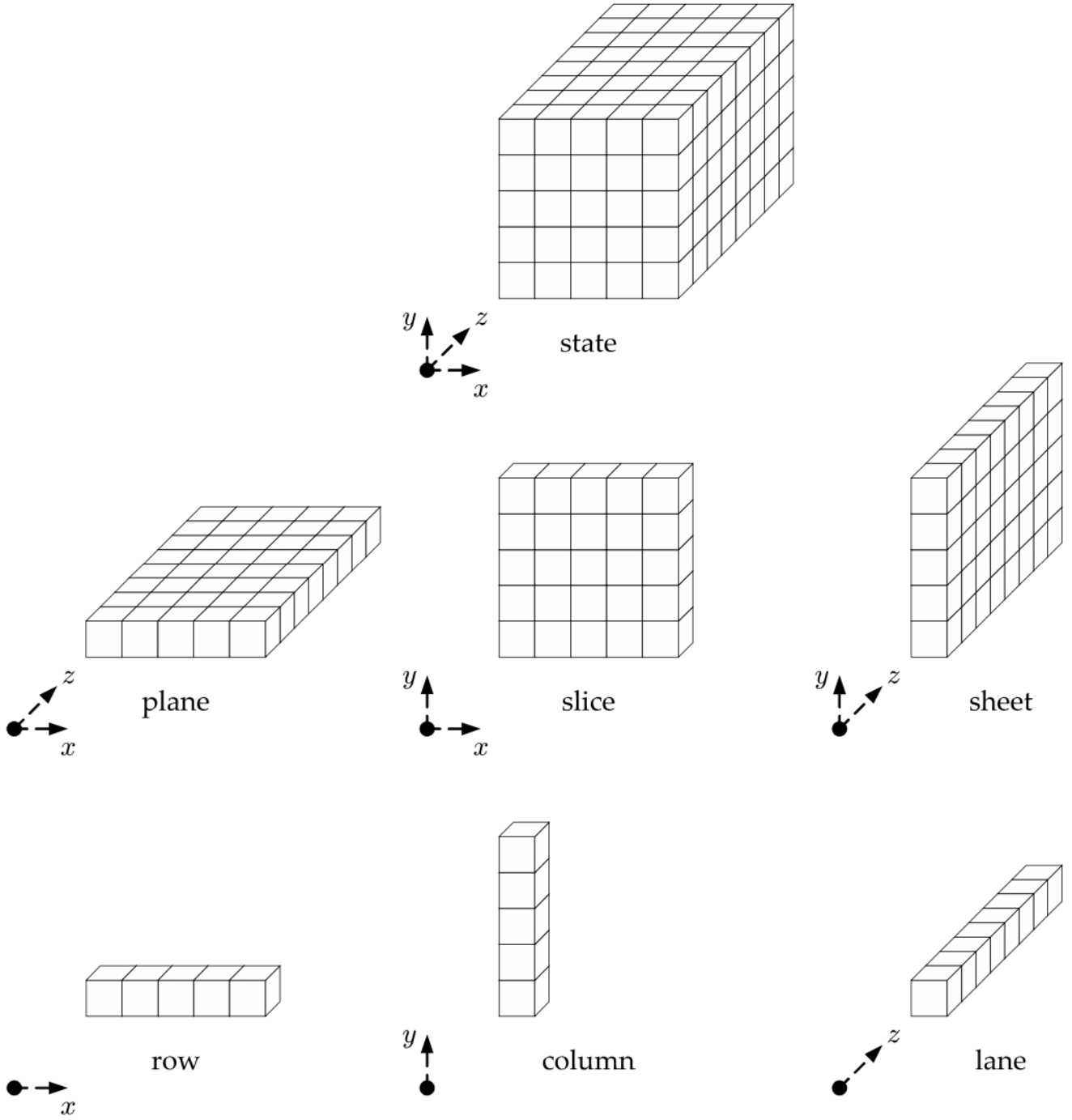
b = 1600
c = 2n, where n ∈ {224, 256, 384, 512}. (inner part)
r = b - c (outer part)

The 1600-bit state can be viewed as a 3-dimensional array of bits, a[5][5][64], and each state bit is associated with 3 integer coordinates, a[x][y][z], where x and y are taken modulo 5, and z is taken modulo 64.

Keccak介绍

2. 数据结构

- row: a[∗][y][z]
- column: a[x][∗][Z]
- lane: a[x][y][∗]
- slice: a[∗][∗][z]

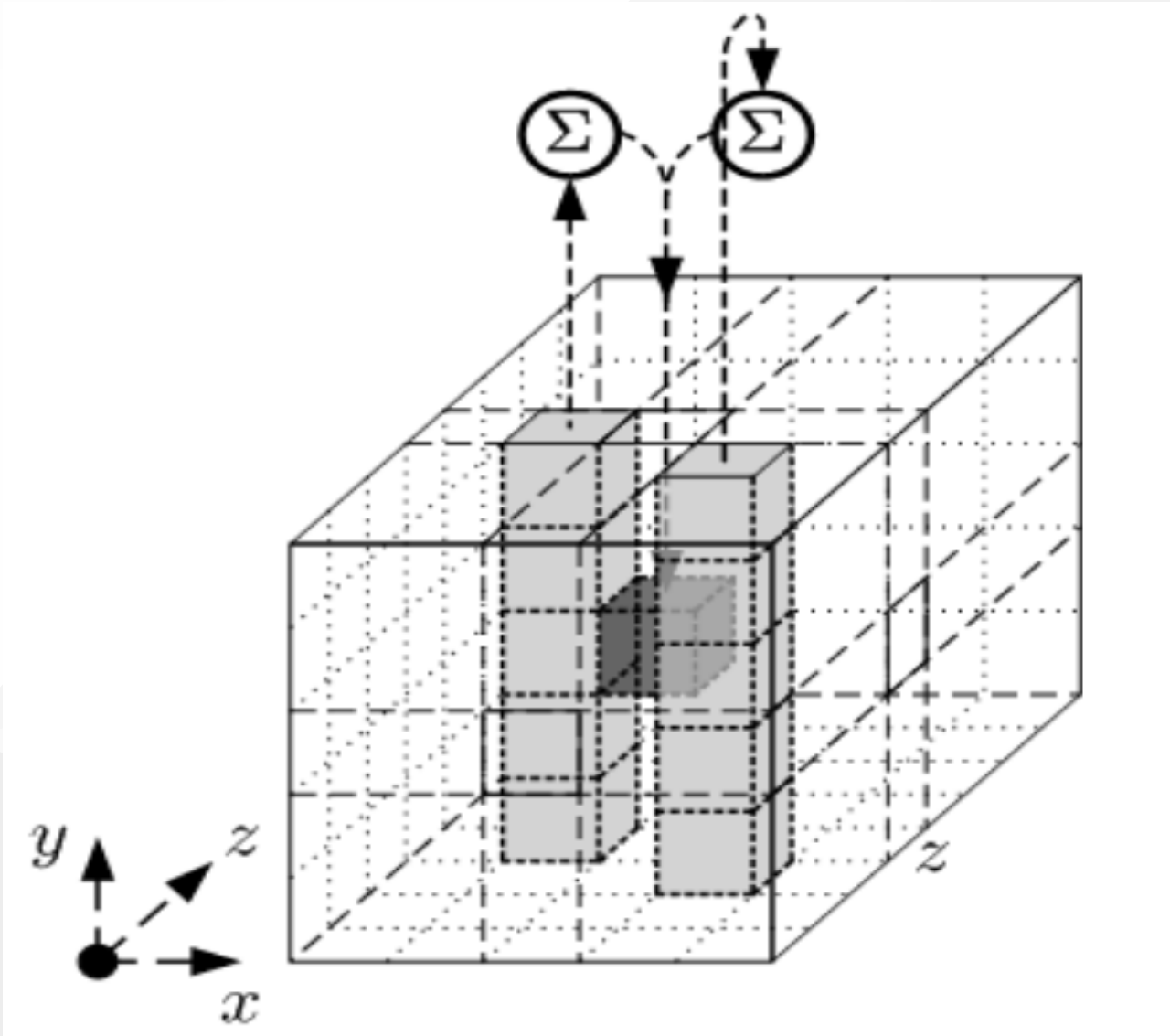


Keccak介绍

3. The Keccak permutation

共24轮。 $R = \iota \circ \chi \circ \pi \circ \rho \circ \boldsymbol{\theta}$.

- θ is a linear map, which adds to each bit in a column, the parity of two other columns.



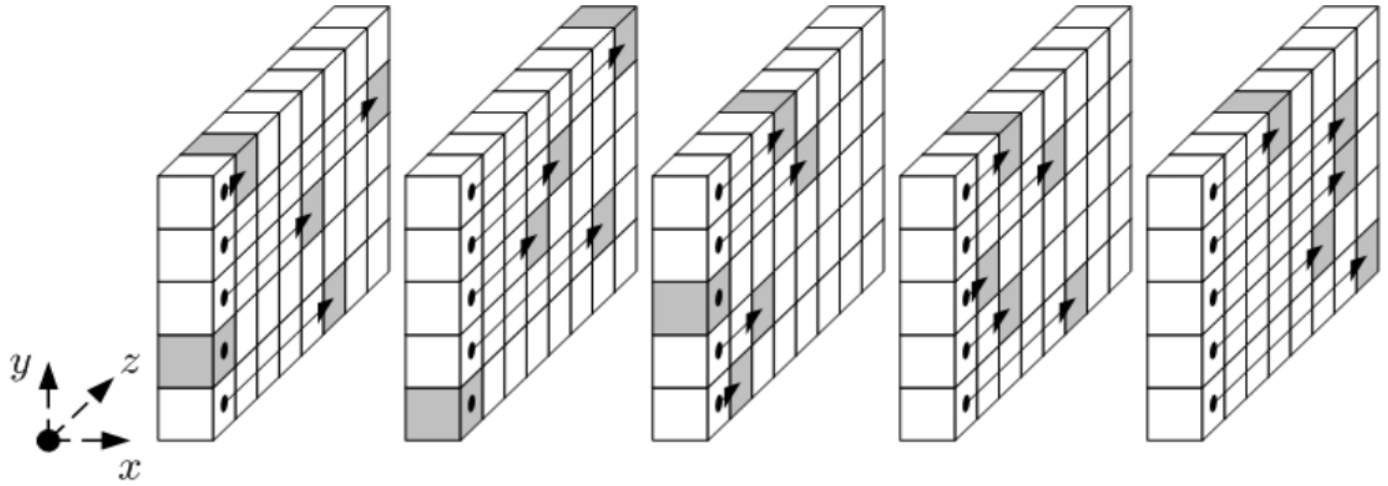
Keccak介绍

3. The Keccak permutation

共24轮。 R = ι ∘ χ ∘ π ∘ **ρ** ∘ θ

- ρ rotates the bits within each lane by T(x,y), which is a predefined constant for each lane.

ρ: a[x][y][z] ← a[x][y][z + T(x, y)]

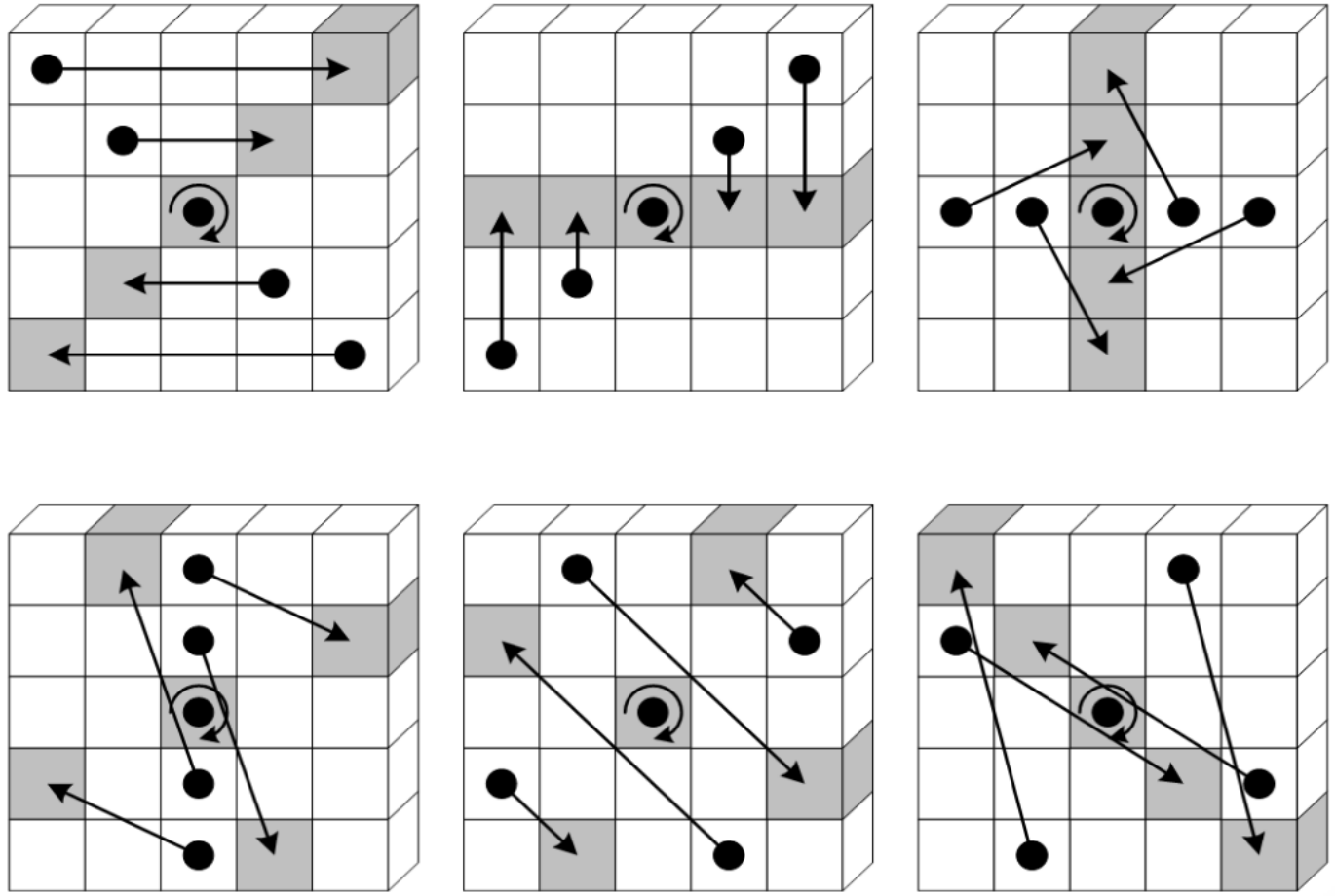


Keccak介绍

3. The Keccak permutation

共24轮。 R = ι ∘ χ ∘ **π** ∘ ρ ∘ θ

- π reorders the lanes.



Keccak介绍

3. The Keccak permutation

共24轮。 $R = \iota \circ \chi \circ \pi \circ \rho \circ \theta$.

χ: $a[x][y][z] \leftarrow a[x][y][z] + ((\neg a[x + 1][y][z]) \wedge a[x + 2][y][z])$

非线性映射

Keccak介绍

3. The Keccak permutation

共24轮。 $R = \iota \circ \chi \circ \pi \circ \rho \circ \theta$.

ι adds a round constant to the state

能攻击的：MD5

MD5碰撞攻击：可以找到两个哈希值相同的不同密文m，m’。[2005年，王小云、于红波， How to break MD5 and Other Hash Funcitons, Eurocrypt 2005.]

- http://www.cmd5.com/ 、http://www.ttmd5.com/ 、http://pmd5.com/ （已知密文查询明文）
- https://www.win.tue.nl/hashclash/fastcoll_v1.0.0.5.exe.zip （对于相同的前缀，生成两个不同的消息，MD5值相同）
- https://github.com/cr-marcstevens/hashclash
  - 对于几乎相同的前缀(只在1个特定位置不同)，生成两个不同的消息，MD5值相同(比较快)
  - 对于几乎相同的前缀(在几个特定位置不同)，生成两个不同的消息，MD5值相同(比较慢)
  - 对于不同的前缀，生成两个不同的消息，MD5值相同(非常慢)

能攻击的：SHA1

- 谷歌发布的SHA1碰撞，找到两个摘要相同但内容不同的PDF：https://shattered.io/
- 在线工具：Quick-and-dirty PDF maker using the collision from the SHAttered paper：https://alf.nu/SHA1

哈希算法本身有漏洞

一些使用者自己设计的哈希算法本身可能有漏洞

例如：算法可逆

通用攻击

暴力攻击：https://hashcat.net/hashcat/

哈希长度拓展攻击：https://github.com/bwall/HashPump

做不到什么

对于目前来看安全的哈希(如SHA-256，SM3)：

- 生成满足特定条件的哈希值
- 生成一个跟特定m哈希值相同的m’(除了m本身)
- 生成两个哈希值相同的m，m’(除非m=m’)

对于这些就基本上不用考虑直接攻击了，因为已经从数学上证明了计算不可行

哈希总结

知道哪些做不到，然后在可能可以做的地方寻找对应的漏洞

非对称加密

常用：RSA

目前为止都是难以暴力破解的，只有短的 RSA 密钥才可能被强力方式解破。

对于某些特殊情况可以攻击

欧几里得算法

- a|b:b%a=0，a是b的因子
- gcd(a,b):最大的满足c|a且c|b的正整数c，最大公约数
- gcd(a,b)=gcd(a-b,b)=gcd(a%b,b)，辗转相除法(欧几里得算法)

```
int gcd(int a, int b){
    if (b == 0)
        return a;
    else
        return gcd(b, a%b);
}
```

扩展欧几里得算法

- 裴蜀定理:ax+by=c有整数解(x,y)的充要条件是gcd(a,b)|c
- 扩展欧几里得算法：ax+by=gcd(a,b)，求x，y和gcd(a,b)

```
int exgcd(int a, int b, int &x, int &y){
    if (b == 0){
        x = 1;y = 0;
        return a;
    }
    int d = exgcd(b, a % b, y, x); //这里交换了x和y
    y -= (a / b) * x;
    return d;
}
```

Zn上的逆元

- 互质:gcd(a,b)=1
- a,n>0，满足 $a * x \ mod \ n = 1$
- 设gcd(a,n)=1，考虑方程ax+nk=1，由裴蜀定理得存在整数解(x,k)

- 存在唯一$0 <= x < n$，满足$a * x \ mod \ n = 1$
- 记$x = a^{-1} \ mod \ n$，称x是a的逆元
- 定义除法：$\frac{a}{b} \ mod \ n = a * b^{-1} \ mod \ n$

- $\phi(n)$:正整数n，$1 <= i <= n$中与n互质的i的个数

RSA加解密流程

- 随机生成两个很大的质数p和q，n=pq，$\phi(n) = (p-1)(q-1)$
- 生成e，满足$gcd(e, \phi(n)) = 1$
- 计算$d = (e^{-1})\ mod\ \phi(n)$
- 公钥为(n,e)，私钥为(n,d)
- 假设明文m为：满足1<=m<n 且 gcd(m,n)=1 的整数
- 加密：密文$c = m^e\ mod\ n$
- 解密：明文$m = c^d\ mod\ n$

RSA攻击思路

- RSA攻击就是：已知n,e,c，且$c = m^e \ mod \ n$。求m
- 而：$m = c^d \ mod \ n$
- 如果知道$\phi(n)$，就可以算出私钥d，进而算出m
- 如果知道p和q，就可以算出$\phi(n)$
- n=p*q，本质上是大整数分解

RSA的安全性

- 对于很大的n，质因数分解是困难问题
- 有多困难？

常用的大整数分解算法：二次筛法，椭圆曲线算法，数域筛法

算法名称	时间复杂度
二次筛法	$O(e^{(1+o(1))*\sqrt{ln(n)*lnln(n)}})$
椭圆曲线算法	$O(e^{(1+o(1))*\sqrt{2ln(p)*lnln(p)}})$
数域筛法	$O(e^{(1.92+o(1))*ln(n)^{\frac{1}{3}}*lnln(n)^{\frac{2}{3}}})$

n为512比特时约需要8000MIPS年。

RSA的安全性

- 对于n=p*q，n已知且p、q未知，算$\phi(n) = (p-1) * (q-1)$和分解n的难度是相同的
- 这意味着已知e求d的难度和分解n是相同的
- 在实际应用场景中，一般p和q至少为512位，n至少为1024位

知道$\phi(n)$和n可以快速分解n

- 如何分解？

RSA的安全性

- 对于n=p*q，n已知且p、q未知，算$\phi(n) = (p-1) * (q-1)$和分解n的难度是相同的
- 这意味着已知e求d的难度和分解n是相同的
- 在实际应用场景中，一般p和q至少为512位，n至少为1024位

知道$\phi(n)$可以快速分解n

- 如何分解？
- $n = pq, \phi(n) = (p-1) * (q-1)$
- $p^2 - (n - \phi(n) + 1)p + pq = 0$
- 一元二次方程求根公式

RSA的安全性

- 刚刚已经知道了大整数分解非常困难
- 标准 RSA 算法在不泄漏任何私钥信息的情况下迄今不存在多项式时间的破解算法
- **对于一些特殊情况可以考虑进行攻击**
- 在实际应用中经常使用特殊的RSA算法

RSA常用攻击方法：直接分解n

- 一般n不超过256bit才能考虑直接分解n

暴力分解常用工具：

- factordb.com
- Sage
- YAFU
- CADO-NFS

p-1光滑时：Pollar p-1

- 光滑数 (Smooth number)：指可以分解为小素数乘积的正整数
- 当p是N的因数，并且p-1是光滑数，可以考虑使用Pollard's p-1算法来分解N [Pollard, John M.. “Theorems on factorization and primality testing.” Mathematical Proceedings of the Cambridge Philosophical Society 76 (1974): 521 - 528.]

- 算法流程：

```
def algorithm(n,B): # n是模数，B是“界”
    a=2
    for j in range(2,B+1):
        a=pow(a,j,n)
    d=GCD(a-1,n)
    if d>1 and d<n:
        return d
    return -1
```

p-1光滑时：Pollar p-1

- 算法证明：
  - 算法假定$p|n$且p是素数，且假定对每一个满足$q|(p-1)$且q是素数的q，都有$q \leq B$。因此一定有：$(p-1)|B!$。
  - for循环结束时有：$a \equiv 2^{B!} \, mod \, n$
  - 因为 $p|n$，因此有：$a \equiv 2^{B!} \, mod \, p$
  - 费马小定理：$2^{p-1} \equiv 1 \, mod \, p$
  - 而$(p-1)|B!$，因此$2^{B!} \equiv 1 \, mod \, p$，$a \equiv 1 \, mod \, p$，因此$p|(a-1)$
  - 因此$d = gcd(a-1, n)$，找到了n的非平凡因子d
- 在线工具：https://mathworld.wolfram.com/Pollardp-1FactorizationMethod.html
- 在实际中：选择两个大素数p_1, q_1使得$p = 2p_1 + 1, q = 2q_1 + 1$也是素数，此时$n = pq$可以抵抗此方法

其他模数选取不当的情况

- p+1光滑：William p+1 算法[Williams, Hugh C.. “A $p+1$ method of factoring.” Mathematics of Computation 39 (1982): 225-234.] https://mathworld.wolfram.com/WilliamspPlus1FactorizationMethod.html
- p-q很小;$\frac{(p+q)^2}{4}-n=\frac{(p+q)^2}{4}-pq=\frac{(p-q)^2}{4}$，因为$|p-q|$很小，所以$\frac{(p-q)^2}{4}$很小，因此$\frac{(p+q)^2}{4}$和$\sqrt{n}$接近。因此可以遍历$\sqrt{n}$附近的整数x，寻找使得$x^2-n=y^2$成立的整数y，然后用平方差公式分解。
- p,q满足$gcd(p-1,q-1)=2g$，其中g是个大素数;
- p,q最低一部分连续比特位相同;
- 等

RSA常用攻击方式：共模攻击

- 同一个m，同一个N，用不同的e1和e2加密，且gcd(e1,e2)=1

明文消息为m，密文分别为：

$$c1 = m^{e1} mod N$$
$$c2 = m^{e2} mod N$$

假设攻击者获得了N，c1，c2。如何获得明文m？

RSA常用攻击方式：共模攻击

- 裴蜀定理：ax+by=c有整数解(x,y)的充要条件是gcd(a,b)|c
- 已知gcd(e1,e2)=1，使用扩展欧几里得算法，解e1x+e2y=1得到x和y
- $m = c1^x * c2^y \ mod \ N$

因为：

$$
\begin{aligned}
c1^x c2^y &\equiv m^{xe1} m^{ye2} mod N \\
&\equiv m^{xe1+ye2} \ mod \ N \\
&\equiv m \ mod \ N
\end{aligned}
$$

RSA常用攻击方式：n1和n2不互素

- 已知多个公钥和对应的密文
- 发现其中存在(N1,e1),(N2,e2)，$gcd(N1, N2) \neq 1$

可直接求得$p1 = gcd(N1, N2), q1 = \frac{N1}{gcd(N1,N2)}$，完成质因数分解

RSA常用攻击方式：小公钥指数攻击

使用小加密指数可以加快公钥加密或签名验证。但e特别小时可能被攻击。

假设用户使用的密钥e=3，此时加密关系满足：

$$c = m^3 mod N$$

即存在正整数k使得 $m^3 = c + k * N$
因此有$m = \sqrt[3]{c + k * N}$
攻击者可以从小到大枚举 k，依次开三次根，直到开出整数为止。

RSA常用攻击方式：Coppersmith的方法

在以下两种情况下可以对小公钥指数加密进行攻击：

- 一类是加密指数较小，同时已知明文的部分比特
- 另一类是使用小加密指数进行重复加密。

在上述两种情况下，Coppersmith 将问题转化为求解单变元模方程的小根问题，使用 LLL 格基约化方法来求解，可以在多项式时间内完全恢复明文。

[Coppersmith D. Small solutions to polynomial equations, and low exponent RSA vulnerabilities[J].Journal of Cryptology, 1997,10(4):233-260.]

RSA常用攻击方式：广播攻击

一个用户使用同一个加密指数 e 加密了同一个密文，并发送给了其他 e 个用户。

以e=3为例说明攻击方法。假设加密者使用了三个不同的模数n1,n2,n3，给三个不同的用户发送了加密后的消息 m。因此有：

$$c1 = m^3 \ mod \ n1$$
$$c2 = m^3 \ mod \ n2$$
$$c3 = m^3 \ mod \ n3$$

这里我们假设n1,n2,n3互素(否则可以直接利用这一点进行质因数分解)
同时，假设 $m < n_i, 1 \leq i \leq 3$。（否则情况较为复杂，暂不讨论）

RSA常用攻击方式：广播攻击

中国剩余定理：$n_1, n_2, \ldots, n_r$都是整数，且对于 $i \neq j$ 有 $gcd(n_i, n_j) \neq 1$。那么：

$$
\begin{aligned}
x &\equiv c_1 mod n_1 \\
x &\equiv c_2 mod n_2 \\
&\ldots \\
x &\equiv c_r mod n_r
\end{aligned}
$$

有唯一解。记$N = n_1 n_2 \ldots n_r$ 则
$x \equiv c_1 N_1 d_1 + c_2 N_2 d_2 + \ldots + c_r N_r d_r mod N$，其中
$N_i = \frac{N}{n_i}, d_i \equiv N^{-1} mod\, n_i$

RSA常用攻击方式：广播攻击

回到e=3的广播攻击情况，根据中国剩余定理，可得

$$m^3 \equiv c_1N_1d_1 + c_2N_2d_2 + c_3N_3d_3 \ mod \ n1 * n2 * n3$$

因为假设了$m < n_i, 1 \leq i \leq 3$，因此可以计算
$c_1N_1d_1 + c_2N_2d_2 + c_3N_3d_3 \ mod \ n1 * n2 * n3$的值并直接开三次根号求得m。

RSA常用攻击方式：维纳攻击

低解密指数也可以加速解密，但是也可能被攻击

- d很小($d < n^{\frac{1}{4}}$)，$q < p < 2q$时，可在多项式时间内分解n
- 工具：https://github.com/pablocelayes/rsa-wiener-attack
- 算法的关键是通过连分数展开，用$\frac{e}{n}$近似$\frac{e}{\phi(n)}$
- 如果p和q的差更小一些，d更大一些的时候也是可以攻击的(用$\frac{e}{n+1-2\sqrt{n}}$做近似)

[Cryptanalysis of RSA with Small Prime Difference,Benne de Weger,2000]

其他

- 侧信道攻击
- 部分私钥泄漏攻击（泄露单个或多个比特块）

RSA总结

能攻击的点并不算多，因为目前为止标准RSA都是难以暴力破解的

在实际应用场景中为了算法效率大量使用特殊 RSA 算法，比标准的算法弱一些（小e，小d等）

使用不当造成漏洞（共模攻击，广播攻击等）

因为有数学证明，所以哪些事情可以做，哪些做不了都比较清楚

对于可能可行的攻击方法挨个尝试即可

练习

https://cloud.tsinghua.edu.cn/d/02e42e3c85b941e8b2eb/

参考文献

- Bertoni, G., Daemen, J., Peeters, M., Van Assche, G.: The Keccak SHA-3 submis- sion. Submission to NIST (Round 3) (2011)
- Dinur, I., Dunkelman, O., Shamir, A. (2012). New Attacks on Keccak-224 and Keccak-256. In: Canteaut, A. (eds) Fast Software Encryption. FSE 2012. Lecture Notes in Computer Science, vol 7549. Springer, Berlin, Heidelberg. https://doi.org/10.1007/978-3-642-34047-5_25
- 王小云、于红波， How to break MD5 and Other Hash Funcitons, Eurocrypt 2005.
- Pollard, John M.. “Theorems on factorization and primality testing.” Mathematical Proceedings of the Cambridge Philosophical Society 76 (1974): 521 - 528.
- Williams, Hugh C.. “A $p+1$ method of factoring.” Mathematics of Computation 39 (1982): 225-234.
- Coppersmith D. Small solutions to polynomial equations, and low exponent RSA vulnerabilities[J].Journal of Cryptology, 1997,10(4):233-260.
- Cryptanalysis of RSA with Small Prime Difference,Benne de Weger,2000
- 石梦. LLL算法在RSA安全性分析中的应用[D].解放军信息工程大学,2013.

Thanks!